

Building a Machine-Readable SKOS Taxonomy of ISO/IEC 27001:2022

ION DONOS, University of Twente, The Netherlands

ISO/IEC 27001:2022 is the leading international standard for information security management, yet it exists only as text documents. Prior Web Ontology Language (OWL) ontologies for earlier versions proved incomplete and difficult to maintain. This paper presents a Simple Knowledge Organization System (SKOS) taxonomy that formalizes 307 concepts from the ISO 27000 family as a queryable knowledge base. Coverage spans ISO 27001 management system clauses, 93 Annex A controls linked to their ISO 27002 implementation guidance, and the foundational ISO 27000 vocabulary. We validate the taxonomy through 32 competency questions translated to SPARQL, the RDF query language, all of which return correct results. An interactive web application provides visual exploration without requiring SPARQL expertise. The taxonomy and visualizations are freely available under the CC-BY-4.0 license.

Additional Key Words and Phrases: SKOS, ISO/IEC 27001:2022, Taxonomy, SPARQL, Competency Questions

1 Introduction

ISO/IEC 27001:2022 has become the dominant international standard for information security management, with certifications growing rapidly worldwide [16]. It defines requirements for an information security management system (ISMS) through two components: management processes (Clauses 4–10) and 93 security controls (Annex A). The management processes specify what an organization must do to establish and maintain an ISMS—for example, understanding organizational context (Clause 4), demonstrating leadership commitment (Clause 5), and planning risk assessments (Clause 6). The controls are organized into four themes—Organizational, People, Physical, and Technological—and specify security measures such as information classification (5.12), labelling of information (5.13), and information transfer (5.14) [15].

Certification requires gap analysis: systematically comparing existing practices against each control to identify deficiencies. The literature identifies this manual comparison process as slow and prone to overlooked controls [3]. A machine-readable representation enables automation of portions of this comparison.

Prior work encoded security standards as Web Ontology Language (OWL) ontologies, enabling querying via SPARQL, the RDF query language [2, 5, 6]. However, these ontologies target outdated versions (2005 or 2013) and evaluations found them structurally rigid, incomplete, and difficult to maintain [18]. As of January 2026, to our knowledge, no general-purpose machine-readable representation exists for the current 2022 edition.

This paper follows design science research methodology [10], producing an artifact—a Simple Knowledge Organization System (SKOS) taxonomy [19]—that addresses this gap and is evaluated

through competency questions [9].¹ The taxonomy centers on ISO 27001 but includes two supporting standards that ISO 27001 itself mandates. Clause 3 specifies that “the terms and definitions given in ISO/IEC 27000 apply.” The Annex A introduction states that controls are “derived from and aligned with ISO/IEC 27002:2022” [15]. Figure 1 illustrates these relationships.

This research addresses the following question: *How should ISO/IEC 27001:2022 be represented as a SKOS taxonomy to enable structured, machine-readable access to its requirements and controls?* Two sub-research questions guide the work:

- **SRQ1:** How can the structural elements and relationships be extracted and encoded while preserving meaning?
- **SRQ2:** Does the taxonomy correctly answer practitioner-focused competency questions when queried via SPARQL?

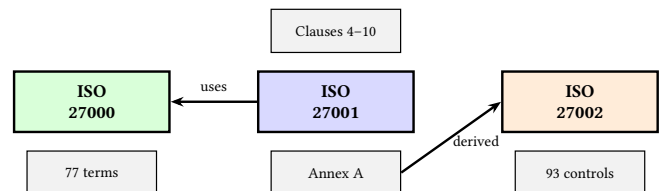


Fig. 1. ISO 27001 depends on two companion standards: vocabulary definitions from ISO 27000 and implementation guidance from ISO 27002.

2 Related Work

Earlier researchers built OWL ontologies for ISO 27001 to support automated audit preparation and semantic queries. Early work established semantic mapping techniques [6], progressed to knowledge formalization [5], and eventually supported compliance determination [7]. These efforts targeted ISO 27001:2005 [5, 6, 20] or ISO 27001:2013 [7]. Related studies extended coverage to ISO 27002 by incorporating human behavioral factors [23], while a systematic review identified the need for integrated security models [2]. One recent study addresses ISO 27001:2022 but focuses on cloud computing [25] rather than providing a general-purpose taxonomy.

Evaluations exposed serious flaws in these OWL approaches. A comparative study of five ISO 27000 family ontologies [18] found three problems. First, structural rigidity: minor standard updates required extensive model rework. Second, incomplete coverage: foundational concepts such as risk assessment and threat identification were absent from several models. Third, poor reproducibility: most lacked documented development methodologies.

Recent foundational ontology research has formalized security concepts from a risk treatment perspective [22], grounding security engineering in established theoretical foundations. However, such approaches require specialized expertise to develop and maintain. These issues motivate exploring SKOS as a simpler alternative.

¹The taxonomy is freely available under the CC-BY-4.0 license. Persistent identifier: <https://w3id.org/wiren301-iso27001-skos/>; source repository: <https://w3id.org/wiren301-iso27001-skos/repo>

Recent research demonstrated that SKOS and Resource Description Framework (RDF) taxonomies can organize cybersecurity standards [17], though that work classifies standards themselves rather than internal control structures. We address this by formalizing ISO 27001’s internal structure—its clauses, controls, and vocabulary. For the transformation process, we adapt a method for converting structured vocabularies to SKOS [27]. This approach suits ISO 27001 due to its clear hierarchical structure (clauses, subclauses, control themes, controls).

For validation, this research employs competency questions (CQs), originally introduced for ontology requirements specification [9]. Prior work produced CQ datasets with SPARQL translations, demonstrating systematic validation approaches [24, 30]. CQs are standard in semantic modeling but, as our review of prior ISO 27001 ontologies found, have not been applied to validate security standard representations.

3 Methodology

3.1 Scope and Standards Selection

The taxonomy draws from three ISO standards in the 27000 family, as mandated by ISO 27001’s normative references (see Figure 1). Including all three lets users query vocabulary, requirements, and implementation guidance in one place. We excluded other 27000-family standards (e.g., ISO 27017 for cloud security) as they extend rather than underpin the core framework.

3.2 SKOS as Representation Language

To understand this choice, consider the difference between a taxonomy and an ontology. A *taxonomy* is a hierarchical classification system that organizes concepts into categories—like a library catalogue or biological classification. An *ontology* goes further: it formally specifies concepts, properties, and logical axioms that enable automated reasoning [8]. OWL implements this vision, allowing statements like “every Organizational control requires management approval”—but this expressiveness comes with overhead. OWL ontologies require logical consistency checking and careful axiom design [28]. As documented in Related Work, prior OWL-based security ontologies proved difficult to maintain in practice [18].

SKOS avoids this complexity [19]. It represents vocabularies and taxonomies using labels, hierarchies, and associative relationships without imposing logical constraints. The trade-off is expressiveness: SKOS cannot encode inference rules. But for ISO 27001, which defines concepts and cross-references rather than logical axioms, this trade-off favors simplicity. SKOS supports SPARQL queries, and its straightforward structure is easier to maintain than OWL class hierarchies.

3.3 Technical Implementation

We represent the taxonomy as an RDF graph [4] and serialize it in two formats. Turtle [1] is used for human inspection because its indented syntax maps naturally to concept hierarchies. JSON-LD [26] is used for web integration. The extraction pipeline uses Python with `rdflib` for graph construction and `pandas` for parsing source Excel files. For query execution, we use Apache Jena ARQ 5.6.0, a standards-compliant SPARQL 1.1 processor that executes

queries directly against Turtle files—using a separate tool from the extraction pipeline confirms the serialized taxonomy is portable and not dependent on `rdflib`-specific behavior.

3.4 Validation Approach

Validation addresses two concerns. First, *structural validation* runs automated checks confirming the taxonomy conforms to SKOS integrity conditions: no cycles in hierarchies, symmetric relations where required, and complete labeling. These checks detect encoding errors before any queries run. Second, *functional validation* tests whether the taxonomy answers practitioner questions. We developed 32 competency questions [9]—queries like “Which controls protect confidentiality?”—and translated each to SPARQL. A passing query returns correct results matching the source documents; a failing query indicates flawed encoding.

4 Building and Validating the Taxonomy

This section details the implementation, following systematic approaches to vocabulary construction [19, 27].

4.1 Revealing the Structure

ISO standards are distributed as PDF documents with no machine-readable API. We therefore manually transcribed content into Excel workbooks. The hard part was designing a schema that handles three document types—vocabulary definitions, management clauses, and security controls—while staying consistent enough for automated processing.

The solution was a unified schema with columns organized into four groups (detailed in Appendix D). These groups address four concerns: *identity* (what is this concept and where does it sit in the hierarchy?), *content* (what does it say?), *attributes* (how is it classified?), and *provenance* (where did it come from?). This unified structure means the same pipeline processes all three standards, while standard-specific columns (e.g., CIA attributes for ISO 27002 controls) remain empty where not applicable.

With content extracted, the next step was mapping to SKOS constructs. The first modeling decision concerned ISO 27001’s clause structure. Clause 6 (“Planning”) contains 6.1, which contains 6.1.1, 6.1.2, and 6.1.3—a tree. SKOS represents trees through `skos:broader` and `skos:narrower`, so the ISMS clauses became a three-level hierarchy.

But hierarchy alone couldn’t capture everything. Annex A control 5.1 and ISO 27002 control 5.1 share the same identifier and meaning, yet appear in different documents—one states the requirement, the other provides guidance. These aren’t parent-child; they’re equivalents. SKOS offers two options: `skos:exactMatch` for interchangeable concepts and `skos:closeMatch` for similar but not identical meanings. We chose `exactMatch` because the controls share identical identifiers and normative content—ISO 27002 elaborates rather than redefines. Every Annex A control received a bidirectional match link to its ISO 27002 counterpart.

A subtler relationship emerged from ISO 27000’s vocabulary. Definitions reference other definitions—“risk” (3.61) explicitly cites “objective” (3.49) using parenthetical notation. These references indicate conceptual association, not subsumption (risk is not a type

of objective), making `skos:related` the appropriate property. A text-matching pattern (regular expression) extracted all “(3.XX)” references and encoded them as bidirectional `skos:related` links.

The final challenge came from ISO 27002’s attribute system. Each control carries multiple classification tags: Confidentiality, Integrity, and Availability (CIA) properties [12], NIST Cybersecurity Framework (CSF) functions [21], operational capabilities, and security domains. A single control might protect all three CIA values and support two NIST CSF functions simultaneously. Hierarchy cannot represent such multiple simultaneous classifications.

The solution was `skos:Collection`, a SKOS grouping mechanism that allows membership without implying hierarchy. Controls group into collections by theme (Organizational, People, Physical, Technological), by CIA property, by NIST function, and by operational capability. Table 1 summarizes the relationship mappings; Table 2 reports the counts.

Clause nesting	broader/narrower	34
Control equivalence	exactMatch	93
Definition cross-refs	related	98
Multi-valued attributes	Collection	33

Pattern → SKOS construct (link count)

Table 1. SKOS Encoding Decisions

Listing 1 shows a representative transformation: ISO 27002 control 5.1 encoded with its label, scheme membership, hierarchical position under the Organizational theme, and equivalence link to Annex A.

```
iso27002:control:5.1 a skos:Concept ;
  skos:prefLabel "Policies for information security" ;
  skos:definition "..."; # truncated
  skos:broader iso27002:theme:organizational ;
  skos:exactMatch iso27001:control:5.1 ;
  skos:inScheme iso27002:ControlsScheme .

iso27002:collection:cia:confidentiality a skos:Collection ;
  skos:prefLabel "Confidentiality" ;
  skos:member iso27002:control:5.1 .
```

Listing 1. Turtle encoding of control 5.1

Figure 2 visualizes the resulting taxonomy. Vocabulary terms appear on the left, connected by violet `related` links. The center shows the Annex A–ISO 27002 coupling as dense red `exactMatch` links. The ISMS clause hierarchy appears in gray on the right. This spatial clustering reflects conceptual boundaries within the standard, while the dense red center shows how tightly requirements and implementation guidance are bound.

4.2 Automation Pipeline

We implemented the encoding decisions described above as an automated Python pipeline, ensuring reproducibility and enabling regeneration as standards evolve (Figure 3). The pipeline parses Excel workbooks, extracts cross-reference patterns, maps content to concepts and collections, establishes semantic relationships, validates structural integrity, and serializes the graph to Turtle and JSON-LD formats. The validation stage proves the taxonomy is well-formed before any queries run against it.

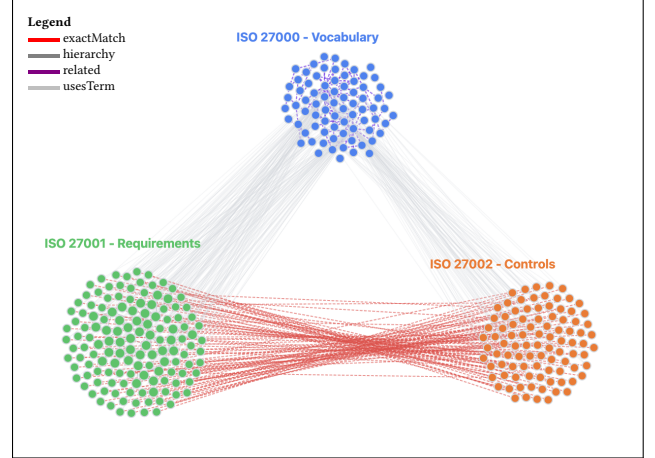


Fig. 2. The taxonomy’s structure at a glance: the dense red cluster (center) shows 93 `exactMatch` links binding Annex A to ISO 27002. Interactive version at project repository.



Fig. 3. Conversion pipeline: Parse, Map, Link, Validate, Serialize.

4.3 Structural Validation

To confirm that the encoding preserves semantic integrity (SRQ1), we implemented eight automated checks—seven derived from SKOS Reference integrity conditions [19] plus one additional quality check:²

- (1) All 307 concepts have labels (S14)
- (2) Each belongs to exactly one scheme (S46)
- (3) No cycles in hierarchies (S27)
- (4) All `related` and `exactMatch` links are symmetric (S23/S44)
- (5) Top-level concepts have no parents (S25)
- (6) No orphans—every concept reachable from a scheme root (quality check)
- (7) No empty labels (S13)
- (8) Notations are unique per scheme (S47)

All checks passed, confirming the taxonomy is well-formed.

4.4 Competency Question Validation

A practitioner implementing ISO 27001 needs more than syntactic correctness: the ability to retrieve requirements, find controls by attribute, and trace relationships across standards. To test whether the taxonomy supports these tasks (SRQ2), we translated each competency question to SPARQL.

Designing for Coverage. Rather than selecting arbitrary questions, we systematically derived competency questions to cover two dimensions: document structure and SKOS constructs. For document structure, we required at least one question per ISMS clause (7), per Annex A theme (4), and per ISO 27000 vocabulary cluster (3). For SKOS constructs, questions must exercise each relationship

²Codes in parentheses (e.g., S14) refer to integrity condition identifiers in the W3C SKOS Reference specification.

type (broader, exactMatch, related, Collection membership) and each retrieval pattern (label lookup, definition retrieval, hierarchy traversal).

This derivation yielded 32 questions organized into seven categories: *Requirement Retrieval*, *Implementation Guidance*, *Control Selection*, *Vocabulary Understanding*, *Navigation*, *Cross-Standard Tracing*, and *Completeness Validation*. This design ensures every clause (4–10), every Annex A theme, and every relationship type is exercised by at least one query.

Execution Environment. Each competency question was encoded as a SPARQL 1.1 query and stored in a dedicated .rq file for reproducibility (32 files total). A shell script executes all queries via Apache Jena ARQ, compares results against expected values, and reports pass/fail status.

Representative Queries. Three examples illustrate the validation approach. First, a requirement retrieval query asks “What are the requirements for leadership commitment?” by selecting the skos:definition of clause 5.1—returning the full normative text that top management shall demonstrate. Second, a control selection query asks “Which controls protect confidentiality?” by finding all members of the CIA/Confidentiality collection—returning 87 controls tagged with this attribute. Third, a cross-standard tracing query asks “Which ISO 27002 control matches A.5.1?” by following the skos:exactMatch link—returning control 5.1 with its implementation guidance. These queries demonstrate that the SKOS encoding preserves queryable access to requirements, attributes, and cross-references.

5 The Resulting Artifact

Having validated both structure and functionality, we characterize the resulting artifact. The extraction and encoding pipeline produced a taxonomy of 307 concepts linked by 225 semantic relationships (Table 2).

Metric	Count
Total Concepts	307
ISO 27000 vocabulary terms	77
ISO 27001 ISMS clauses	44
ISO 27001 Annex A controls	93
ISO 27002 controls	93
Concept Schemes	5
Collections	33
exactMatch links	93
related links	98
broader/narrower links	34
Total RDF Triples	3,176

Table 2. Taxonomy Statistics. The 93 exactMatch links bridge compliance requirements (Annex A) and implementation guidance (ISO 27002).

To assess practical utility, we tested the taxonomy through 32 competency questions spanning seven categories (Table 3).

Category	CQs	Passed
A. Requirement Retrieval	7	7
B. Implementation Guidance	4	4
C. Control Selection	5	5
D. Vocabulary Understanding	5	5
E. Navigation & Structure	4	4
F. Cross-Standard Tracing	3	3
G. Completeness Validation	4	4
Total	32	32

Table 3. Competency Question Validation Summary

The categories cover realistic practitioner tasks: retrieving normative requirements, accessing implementation guidance via cross-standard links, filtering controls by CIA or NIST attributes, navigating clause hierarchies, and validating completeness (see Appendix C for details).

Listing 2 shows the SPARQL translation for the confidentiality query introduced earlier; results are organized by parent theme, enabling practitioners to quickly identify relevant controls.

```
PREFIX skos: <http://www.w3.org/2004/02/skos/core#>
PREFIX iso27002: <https://wiren301.github.io/iso27001-skos-taxonomy/iso27002/>

SELECT ?control ?label ?theme
WHERE {
  iso27002:collection:cia:confidentiality
    skos:member ?control .
  ?control skos:prefLabel ?label ;
    skos:broader ?themeUri .
  ?themeUri skos:prefLabel ?theme .
}
ORDER BY ?theme ?label
```

Listing 2. SPARQL query: Controls protecting confidentiality

To make the taxonomy accessible beyond SPARQL queries, we provide an interactive web application built with React and D3.js. The interface offers multiple views: per-standard graph visualizations with force-directed layouts, a merged view showing cross-standard relationships, and a practitioner-oriented browser. The browser links ISMS requirements to their corresponding ISO 27002 controls while highlighting vocabulary terms in context.

The artifact adheres to FAIR principles [29]: the public GitHub repository with structured metadata makes it *Findable*; a persistent w3id.org identifier and CC-BY-4.0 license ensure *Accessibility*; RDF and SKOS standards enable *Interoperability* with other knowledge bases; and the taxonomy was designed specifically for *Reuse* in compliance tools and gap analysis.

5.1 Practical Application: Gap Analysis

Consider a compliance team preparing for ISO 27001 certification. They need to identify which Asset Management controls require documented operating procedures. Traditionally, this requires cross-referencing the standard’s PDF manually—scanning Annex A for asset-related controls, then consulting ISO 27002 for implementation guidance.

With the taxonomy, a single SPARQL query retrieves all controls under the Asset Management operational capability that reference documented procedures, returning both the control statement and its implementation guidance. The query executes in milliseconds and returns structured results that can be exported directly to a compliance tracking spreadsheet.

Beyond individual queries, the practitioner interface (Figure 5) allows auditors to explore relationships visually. Selecting a clause displays its linked ISO 27002 control with implementation guidance and attribute tags. Vocabulary terms are highlighted in context with definitions on hover. This traceability—from high-level requirement to implementation detail—reduces the manual effort of cross-referencing documents and ensures no mappings are overlooked during audit preparation.

6 What the Taxonomy Reveals

Beyond confirming that the taxonomy answers practical queries, the validation process revealed structural patterns in the source standards themselves. The network is notably sparse: the 225 semantic relationships yield 508 directed edges (symmetric properties like `exactMatch` and `related` generate bidirectional links). This gives an undirected density of just 1.08% among 307 nodes. This sparsity mirrors the source documents—ISO standards present requirements and controls as separate items, not as a web of interconnected concepts.

6.1 Control Equivalence Between Standards

The 93 `skos:exactMatch` links enable bidirectional navigation between compliance requirements (Annex A) and implementation guidance (ISO 27002). Queries can start from either standard and reach the other, supporting both “what controls apply?” and “how do I implement this?” workflows.

6.2 Vocabulary Cross-References as Knowledge Structure

The 98 `skos:related` links within ISO 27000 vocabulary reveal how the standard’s authors conceived relationships between concepts (Figure 6). Network analysis exposes significant centrality concentration. Three terms serve as hubs: “organization” (3.50), “information security” (3.28), and “process” (3.54). Each participates in substantially more relationships than average. With 98 bidirectional links across 77 terms, the mean degree is 2.5 connections per term; these three hubs each have 10–12 connections. This concentration reflects ISO 27001’s governance-centric design: “organization” anchors management responsibility, “information security” defines the domain, and “process” connects operational activities.

Terms like “risk” (3.61) are also highly connected, referencing “objective,” “event,” “likelihood,” and “consequence”—forming a conceptual cluster around risk management. The source text contains this network structure implicitly through parenthetical references, but the taxonomy makes it explicit and queryable. Practitioners can now explore semantic neighborhoods: given any term, they can discover related concepts the standard considers relevant.

6.3 Hierarchical Depth and Document Structure

The clause hierarchy reflects ISO 27001’s organizational structure (Figure 7). The 34 `skos:broader/skos:narrower` links organize

seven top-level clauses (4–10) containing subclauses up to three levels deep (e.g., 6.1.2). By contrast, Annex A controls are flat—organized by theme but without sub-control nesting. This structural difference is significant: requirements have complex interdependencies (a clause may depend on understanding its parent context), while individual controls are atomic actions. The taxonomy preserves this distinction, enabling hierarchical queries for requirements and flat filtering for controls.

6.4 Multi-Dimensional Control Classification

The 33 `skos:Collection` instances enable representing controls as inherently multi-dimensional (Figure 8). A single control may belong to the Organizational theme, protect all three CIA properties, support the NIST Protect function, and fall under the Asset Management operational capability. Traditional hierarchies cannot represent such membership; SKOS collections provide exactly this capability.

Analysis reveals asymmetric distribution across classification dimensions. For CIA properties, 73 controls (78.5%) protect all three pillars, while 20 (21.5%) selectively omit one or more—with none tagged for only Availability or only Confidentiality. This pattern distinguishes infrastructure safeguards (full CIA) from organizational/governance measures (selective CIA), a distinction implicit in ISO 27002 but now queryable.

The NIST Cybersecurity Framework alignment shows strong skew toward prevention (Figure 4). Protect and Identify together account for 75% of mappings, while Respond and Recover—the incident management functions—cover 17 controls combined. This concentration reflects ISO 27001’s origins in proactive risk management rather than incident response. CQ13 (“Which controls support NIST Protect function?”) returns 71 controls, confirming this preventive focus.

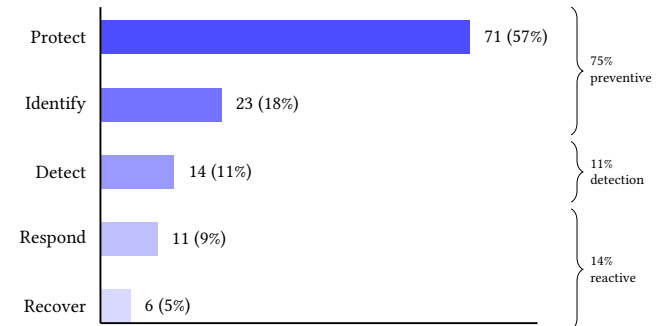


Fig. 4. ISO 27002 controls mapped to NIST Cybersecurity Framework functions. The standard emphasizes prevention (Protect, Identify) over incident response (Respond, Recover). Note: controls may map to multiple functions.

7 Conclusion

We built a machine-readable SKOS taxonomy of ISO/IEC 27001:2022. As of January 2026, this is the first SKOS-based representation of the current standard, complementing prior OWL ontologies that targeted earlier editions. The taxonomy encodes 307 concepts across five schemes with 225 semantic relationships (Table 2).

Eight automated validation checks confirmed structural correctness. The competency questions demonstrate the taxonomy handles common practitioner queries: requirement lookups, control filtering, cross-standard tracing, and vocabulary exploration.

The taxonomy's sparsity (1.08% density) reflects the source standard's design rather than a modeling limitation. ISO 27001 deliberately presents controls as independent items, enabling selective implementation based on risk assessment. This modularity is intentional.

The vocabulary's hub structure—centered on “organization,” “information security,” and “process”—confirms that ISO 27001 is a governance framework, not a technical one. Organizations approaching certification as a technology deployment rather than an organizational transformation will find the standard's requirements misaligned with their expectations.

The NIST mapping reveals a structural gap. With 75% of controls supporting prevention (Protect, Identify) and only 14% addressing incident response (Respond, Recover), ISO 27001 certification does not imply comprehensive security coverage. Practitioners should supplement the standard with dedicated incident response capabilities.

The RDF serialization supports three primary applications. Compliance teams (with technical support or appropriate tooling) can filter controls by attributes. Security architects can trace from requirements to implementation guidance via `skos:exactMatch` links. Tool developers can integrate the stable URI structure into Governance, Risk, and Compliance (GRC) platforms.

Methodologically, this work demonstrates that SKOS provides appropriate formalization for standards that classify and label rather than enable logical inference. Prior OWL ontologies imposed deductive structures onto content that requires none. SKOS's lightweight semantics—hierarchies, associations, and collections—match the nature of compliance frameworks.

7.1 Limitations

The taxonomy represents a static snapshot of the 2022 editions; when ISO publishes revisions, the extraction must be repeated.

The current implementation supports only English. ISO standards are published in multiple languages, and multilingual support requires additional extraction with language-tagged `skos:prefLabel` annotations.

Finally, the competency questions were designed by the researcher to systematically cover document structure and SKOS constructs, rather than elicited from practicing security professionals. This creates a potential construct validity threat. The questions may not reflect real-world information needs. Additionally, the 100% pass rate may simply indicate alignment between the taxonomy design and test design rather than fitness for practice. A user study with compliance practitioners would provide stronger validation but was beyond the scope of this project.

7.2 Future Work

The next step is expanding coverage within the ISO 27000 family. Standards like ISO 27017 [11] (cloud security), ISO 27018 [13] (PII

protection), and ISO 27701 [14] (privacy) share the same structural patterns and could be integrated using the existing pipeline.

Beyond the ISO family, mapping to other security frameworks—NIST Cybersecurity Framework, CIS Controls, COBIT—would enable cross-framework compliance queries and gap analysis.

Future work should add natural language search, integrate with compliance tools, or automate gap analysis. Multilingual labels would broaden accessibility to non-English speakers working with ISO's French, German, and Spanish editions.

Acknowledgments

The author thanks Ítalo Oliveira and Dipti Sarmah for their valuable feedback and guidance throughout this research.

AI tools assisted at several stages of this research. Gemini Papers (Google) helped identify relevant prior work, including references [17], [27], [24], and [25]—all verified against primary sources. Claude Opus 4.5 (Anthropic) assisted with code development. Grammarly was used for grammar checking. The author critically evaluated all AI-generated content and takes full responsibility for the accuracy and integrity of the final work.

References

- [1] David Beckett, Tim Berners-Lee, Eric Prud'hommeaux, and Gavin Carothers. 2014. *RDF 1.1 Turtle: Terse RDF Triple Language*. W3C Recommendation. W3C. <https://www.w3.org/TR/turtle/>
- [2] Carlos Blanco, Javier Lasheras, Eduardo Fernández-Medina, Rafael Valencia-García, and Ambrosio Tóval. 2011. Basis for an Integrated Security Ontology. *Computer Standards & Interfaces* 33, 4 (2011), 372–388. doi:10.1016/j.csi.2010.08.002
- [3] Giovanna Culot, Guido Nassimbeni, Matteo Podrecca, and Marco Sartor. 2021. The ISO/IEC 27001 information security management standard: Literature review and theory-based research agenda. *The TQM Journal* 33, 7 (2021), 76–105. doi:10.1108/TQM-09-2020-0202
- [4] Richard Cyganiak, David Wood, and Markus Lanthaler. 2014. *RDF 1.1 Concepts and Abstract Syntax*. W3C Recommendation. W3C. <https://www.w3.org/TR/rdf11-concepts/>
- [5] Stefan Fenz and Andreas Ekelhart. 2009. Formalizing Information Security Knowledge. In *Proceedings of the 4th International Symposium on Information, Computer, and Communications Security*. ACM, 183–194. doi:10.1145/1533057.1533084
- [6] Stefan Fenz, Gernot Goluch, Andreas Ekelhart, Bernhard Riedl, and Edgar Weippl. 2007. Information Security Fortification by Ontological Mapping of the ISO/IEC 27001 Standard. In *Proceedings of the 13th Pacific Rim International Symposium on Dependable Computing*. IEEE, 381–388. doi:10.1109/PRDC.2007.29
- [7] Stefan Fenz, Stefanie Plieschnegger, and Heiko Hobel. 2016. Ontology-based Information Security Compliance Determination. *Information & Computer Security* 24, 5 (2016), 552–567. doi:10.1108/ICS-07-2015-0030
- [8] Thomas R. Gruber. 1993. A Translation Approach to Portable Ontology Specifications. *Knowledge Acquisition* 5, 2 (1993), 199–220. doi:10.1006/knac.1993.1008
- [9] Michael Grüninger and Mark S. Fox. 1995. The Role of Competency Questions in Enterprise Engineering. In *Benchmarking—Theory and Practice*. Springer, 22–31. doi:10.1007/978-0-387-34847-6_3
- [10] Alan R. Hevner, Salvatore T. March, Jinsoo Park, and Sudha Ram. 2004. Design Science in Information Systems Research. *MIS Quarterly* 28, 1 (2004), 75–105. doi:10.2307/25148625
- [11] International Organization for Standardization. 2015. ISO/IEC 27017:2015 Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services. Standard. <https://www.iso.org/standard/43757.html>
- [12] International Organization for Standardization. 2018. ISO/IEC 27000:2018 Information technology — Security techniques — Information security management systems — Overview and vocabulary. Standard. <https://www.iso.org/standard/73906.html>
- [13] International Organization for Standardization. 2019. ISO/IEC 27018:2019 Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors. Standard. <https://www.iso.org/standard/76559.html>
- [14] International Organization for Standardization. 2019. ISO/IEC 27701:2019 Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy

- information management — Requirements and guidelines. Standard. <https://www.iso.org/standard/71670.html>
- [15] International Organization for Standardization. 2022. ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Standard. <https://www.iso.org/standard/82875.html>
 - [16] International Organization for Standardization. 2024. The ISO Survey of Management System Standard Certifications 2023. <https://www.iso.org/the-iso-survey.html> Accessed January 2025.
 - [17] Eleni-Maria Kalogeraki, Dimitris Apostolou, Despina Polemi, and Stefanos Papastergiou. 2024. A Taxonomy for Cybersecurity Standards. *Journal of Surveillance, Security and Safety* 5 (2024), 95–115. doi:10.20517/jsss.2023.50
 - [18] Ines Meriah and Latifa Ben Arfa Rabai. 2019. Comparative Study of Ontologies Based ISO 27000 Series Security Standards. *Procedia Computer Science* 160 (2019), 85–92. doi:10.1016/j.procs.2019.09.447
 - [19] Alistair Miles and Sean Bechhofer. 2009. *SKOS Simple Knowledge Organization System Reference*. W3C Recommendation. W3C. <https://www.w3.org/TR/skos-reference/>
 - [20] Dragan Milicevic and Matthias Goeken. 2010. Ontology-based Evaluation of ISO 27001. In *Conference on e-Business, e-Services and e-Society (I3E)*. Springer, 93–102. doi:10.1007/978-3-642-16283-1_13
 - [21] National Institute of Standards and Technology. 2018. *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*. Technical Report. NIST. doi:10.6028/NIST.CSWP.04162018
 - [22] Ítalo Oliveira, Tiago Prince Sales, Riccardo Baratella, Mattia Fumagalli, and Giancarlo Guizzardi. 2022. An Ontology of Security from a Risk Treatment Perspective. In *Conceptual Modeling: 41st International Conference, ER 2022 (Lecture Notes in Computer Science, Vol. 13607)*. Springer, 365–379. doi:10.1007/978-3-031-17995-2_26
 - [23] Simon E. Parkin, Aad van Moorsel, Robert Coles, and Robin Sharp. 2009. An Information Security Ontology Incorporating Human-behavioural Implications. In *Proceedings of the 2nd International Conference on Security of Information and Networks*. ACM, 46–55. doi:10.1145/1626195.1626209
 - [24] Jędrzej Potoniec, Dawid Wiśniewski, Agnieszka Lawrynowicz, and C. Maria Keet. 2020. Dataset of Ontology Competency Questions to SPARQL-OWL Queries Translations. *Data in Brief* 29 (2020), 105098. doi:10.1016/j.dib.2019.105098
 - [25] Morteza Sargolzaei Javan. 2025. A Semantic Model for Audit of Cloud Engines Based on ISO/IEC TR 3445:2022. arXiv preprint arXiv:2510.09690. <https://arxiv.org/abs/2510.09690>
 - [26] Manu Sporny, Dave Longley, Gregg Kellogg, Markus Lanthaler, Pierre-Antoine Champin, and Niklas Lindström. 2020. *JSON-LD 1.1: A JSON-based Serialization for Linked Data*. W3C Recommendation. W3C. <https://www.w3.org/TR/json-ld11/>
 - [27] Mark Van Assem, Véronique Malaisé, Alistair Miles, and Guus Schreiber. 2006. A Method to Convert Thesauri to SKOS. In *The Semantic Web: Research and Applications (LNCS, Vol. 4011)*, York Sure and John Domingue (Eds.). Springer, 95–109. doi:10.1007/11762256_10
 - [28] W3C OWL Working Group. 2012. *OWL 2 Web Ontology Language Document Overview*. W3C Recommendation. W3C. <https://www.w3.org/TR/owl2-overview/>
 - [29] Mark D. Wilkinson, Michel Dumontier, IJsbrand Jan Aalbersberg, et al. 2016. The FAIR Guiding Principles for Scientific Data Management and Stewardship. *Scientific Data* 3 (2016), 160018. doi:10.1038/sdata.2016.18
 - [30] Dawid Wiśniewski, Jędrzej Potoniec, Agnieszka Lawrynowicz, and C. Maria Keet. 2019. Analysis of Ontology Competency Questions and their Formalizations in SPARQL-OWL. *Journal of Web Semantics* 59 (2019), 100534. doi:10.1016/j.websem.2019.100534

Annex A Practitioner Interface

A.5.1Policies for information security

DEFINITION

Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.

VOCABULARY TERMS USED

policy

intentions and direction of an organization (3.50), as formally expressed by its top management (3.75)

information security

preservation of confidentiality (3.10), integrity (3.36) and availability (3.7) of information

ISO 27002 CONTROL (EXACTMATCH)

5.1Organizational

Policies for information security

PURPOSE

To ensure continuing suitability, adequacy, effectiveness of management direction and support for information security in accordance with business, legal, statutory, regulatory and contractual requirements.

CONTROL

Information security policy and topic-specific policies should be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.

CIA: C I A

NIST: Identify

Capability: Governance

Domain: Governance and Ecosystem Resilience

Implementation Guidance

Fig. 5. Practitioner view showing Annex A control (A.5.1) with highlighted vocabulary terms, their definitions, and the linked ISO 27002 control with implementation guidance and attribute tags (CIA, NIST, Capability, Domain).

Annex B Per-Standard Visualizations

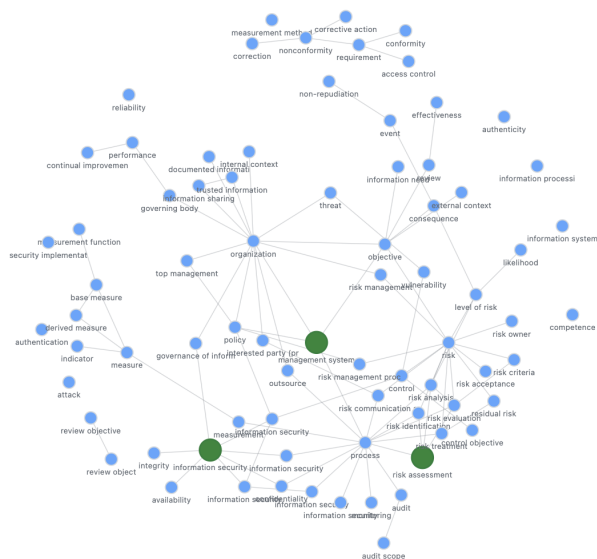


Fig. 6. ISO/IEC 27000:2018 vocabulary term network showing skos:related links extracted from definition cross-references.

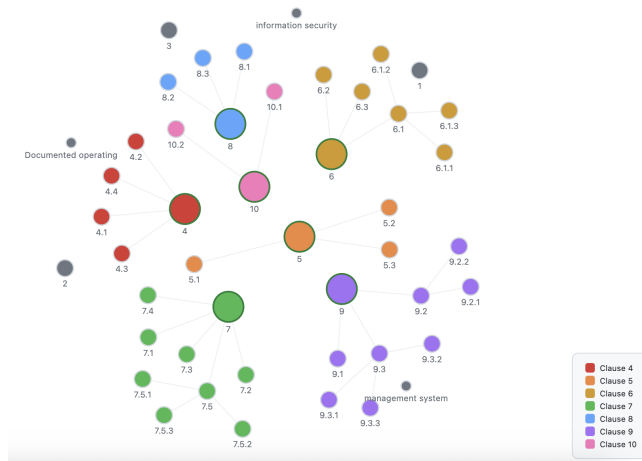


Fig. 7. ISO/IEC 27001:2022 ISMS requirements hierarchy (Clauses 4–10) showing skos:broader/skos:narrower relationships.

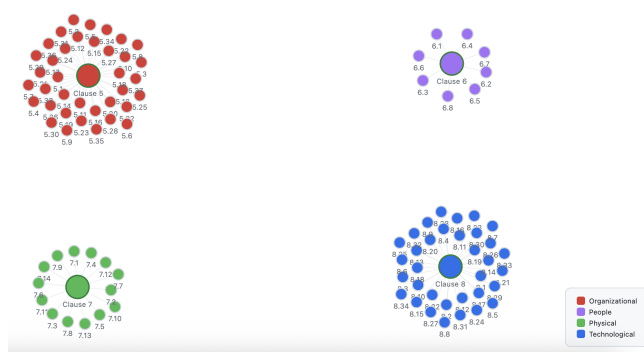


Fig. 8. ISO/IEC 27002:2022 controls organized by theme collections: Organizational (37), Technological (34), Physical (14), People (8).

Annex C Complete Competency Question Validation

Table 4. Complete Competency Question Results

CQ	Question	Expected Result	Pass
Category A: Requirement Retrieval			
1	What are the requirements for leadership commitment?	Clause 5.1 definition text	✓
2	What sub-requirements exist for leadership?	Items a–h from 5.1 notes	✓
3	What must the security policy include?	Clause 5.2 requirements a–g	✓
4	What are the risk assessment requirements?	Clause 6.1.2 definition	✓
5	What are the risk treatment requirements?	Clause 6.1.3 definition	✓
6	What documentation is required?	Clause 7.5 requirements	✓
7	What are the monitoring requirements?	Clause 9.1 definition	✓
Category B: Implementation Guidance			
8	How should I implement access control?	ISO 27002:5.15 guidance	✓
9	How should I implement information classification?	ISO 27002:5.12 guidance	✓
10	What is the purpose of control A.5.1?	ISO 27002:5.1 definition	✓
11	What guidance exists for user access management?	Controls 5.16–5.18 guidance	✓
Category C: Control Selection			
12	Which controls protect confidentiality?	87 controls	✓
13	Which controls support NIST Protect function?	71 controls	✓
14	Which controls are organizational?	37 controls	✓
15	Which controls are technological?	34 controls	✓
16	Which controls address asset management?	Asset management controls	✓
Category D: Vocabulary Understanding			
17	What is the definition of “risk”?	ISO 27000 term 3.61 definition	✓
18	What is “information security”?	“preservation of C-I-A”	✓
19	What terms relate to “risk”?	Related vocabulary terms	✓
20	What is a “control”?	ISO 27000 term 3.14 definition	✓
21	What is “vulnerability”?	ISO 27000 term 3.77 definition	✓
Category E: Navigation & Structure			
22	What clauses fall under Planning (6)?	6.1, 6.2, 6.3	✓
23	What is the parent clause of 6.1.3?	Clause 6.1	✓
24	What are the main ISMS clauses?	Clauses 4, 5, 6, 7, 8, 9, 10	✓
25	How many clauses total?	44 clauses	✓
Category F: Cross-Standard Tracing			
26	Which ISO 27002 control matches A.5.1?	27002:5.1	✓
27	Which Annex A control matches 27002:5.15?	A.5.15	✓
28	How many control pairs exist?	93 exactMatch pairs	✓
Category G: Completeness Validation			
29	Total Annex A controls?	93 controls	✓
30	Total vocabulary terms?	77 terms	✓
31	Total cross-references in vocabulary?	98+ related links	✓
32	All controls have definitions?	0 missing	✓

Annex D Extraction Schema

Group	Column	Description
Identity	Concept_ID	Unique identifier (e.g., A.5.15, 3.28)
	Label	Human-readable name
	Definition	Full text definition or statement
	Parent_ID	Hierarchical parent reference
	Theme	Classification category
Content	Note_1–6	Additional annotations
	Purpose	Control objective (ISO 27002)
	Guidance	Implementation guidance
	Other_Info	Supplementary information
Attributes	Attr_CIA	Confidentiality, Integrity, Availability
	Attr_Cyber	NIST cybersecurity functions
	Attr_Ops_Cap	Operational capabilities
	Attr_Sec_Domain	Security domains
	Attr_Control_Type	Preventive, Detective, Corrective
Provenance	External_Ref	Cross-references to other standards
	Sub_Items	Nested list items
	Requirement_Type	Requirement classification
	Source	Source document reference